CSKG4APT: A Cybersecurity Knowledge Graph for Advanced Persistent Threat Organization Attribution

Yitong Ren, Yanjun Xiao, Yinghai Zhou, Zhiyong Zhang, and Zhihong Tian, *Senior Member, IEEE*

Abstract—Open-source cyber threat intelligence (OSCTI) is becoming more influential in obtaining current network security information. Most studies on cyber threat intelligence (CTI) focus on automating the extraction of threat entities from public sources that describe attack events. The cybersecurity knowledge graph aims to change the expression of threat knowledge so that security researchers can accurately and efficiently obtain various types of threat information for preliminary intelligent decisions. The attribution technology can not only assist security analysts in detecting advanced persistent threats, but can also identify the same threat from different attack events. Therefore, it is important to trace the attack threat actor. In this study, we used the knowledge graph technology, considered the latest research on cyber threat attack attribution, and thoroughly examined key related technologies and theories in the process of constructing and applying the advanced persistent threat (APT) knowledge graph from OSCTI. We designed a cybersecurity platform named CSKG4APT based on a knowledge graph. Inspired by the theory of ontology, we constructed CSKG4APT as an APT knowledge graph model based on real APT attack scenarios. We then designed an APT threat knowledge extraction algorithm for completing and updating the knowledge graph using deep learning and expert knowledge. Finally, we proposed a practical APT attack attribution method with attribution and countermeasures. CSKG4APT is not a passive defense method in traditional network confrontation but one that integrates a large amount of fragmented intelligence and can actively adjust its defense strategy. It lays the foundation for further dominance in network attack and defense.

Index Terms—Cyber threat intelligence, cybersecurity knowledge graph, APT organization attribution, diamond model

1 Introduction

Owing to the rapid growth of computer data and the development of artificial intelligence technologies, cyber attacks have become increasingly sophisticated and diversified while cybersecurity has become more challenging. A general term in the industry is advanced persistent threat (APT) attacks, which was first proposed by the U.S. Department of Defense and the U.S. Air Force. APT attacks refer to the persistent attacks against important assets of enterprises or key national infrastructure as well as important government departments by advanced technical means, hacker organizations, and national backgrounds. An APT attack is a long-term, persistent network attack on a specific target using advanced and hidden attack methods [1]. According to a Kaspersky APT report [2], the style and threat level of APT attacks have evolved in the past year. The attacks vary (e.g., supply-chain attacks and firmware vulnerabilities), and no single cybersecurity vendor completely identifies the activities of all threat actors. Fig. 1 presents the major APT attacks recorded in the past ten years.

Recent APT attacks, as illustrated in Fig. 1, have proven that traditional network security defenses have become ineffective against APT attacks. The diminished ineffectiveness lies in the information asymmetry between the attacker and defender. The attacker can easily obtain the identity information of the defender, who would find it difficult to obtain any information about the attacker before the attack occurs. An active collection of information about network threats is a major way of preventing network attacks and the rapidly evolving threats of information imbalance between attackers and defenders. Cyber threat intelligence (CTI) has also become prominent in enhancing the ability to resist network threats [3]. More cybersecurity personnel and organizations are now willing to exchange and share CTI to improve their cybersecurity defense capabilities as threat intelligence drives network security defense in the field of cybersecurity. Timely intelligence sharing and accurate intelligence analysis are the keys to effectively responding to network threats. More intuitively, the sharing and utilization of CTI is a kind of advanced security protection strategy of "space for time." By proactively acquiring existing or potential network threats and limiting the attack time and scope, the threat response time is considerably shortened, thus changing the asymmetry in the process of offensive and defensive

- *Yitong Ren, Yinghai Zhou, Zhiyong Zhang, and Zhihong Tian are with the Cyberspace Institute of Advanced Technology, Guangzhou University, Guangzhou, Guangdong 510006, China. E-mail: {renyitong, zhangzhiyong1}@e.gzhu.edu.cn, zyh369898622@163.com, tianzhihong@gzhu.edu.cn.*
- *Yanjun Xiao is with PINGXING Lab (Nsfocus Technology Group Company), Guangdong 510663, China. E-mail: xiaoyanjun@nsfocus.com.*

Manuscript received 27 Dec. 2021; revised 24 Apr. 2022; accepted 12 May 2022. Date of publication 20 July 2022; date of current version 1 May 2023.
This work was supported by the National Natural Science Foundation of China under Grant U20B2046, in part by the National Key Research and Development Program of China under Grant 2021YFB2012402, in part by Guangdong Province Universities and Colleges Pearl River Scholar Funded Scheme(2019), and in part by Guangzhou University Graduate Student Innovation Ability Training Funding Program under Grant 2021GDJC-D17.
(Corresponding author: Zhihong Tian.)
Recommended for acceptance by Y. Zhang.
Digital Object Identifier no. 10.1109/TKDE.2022.3175719

1041-4347 © 2022 IEEE. Personal use is permitted, but republication/redistribution requires IEEE permission.
See https://www.ieee.org/publications/rights/index.html for more information.
Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

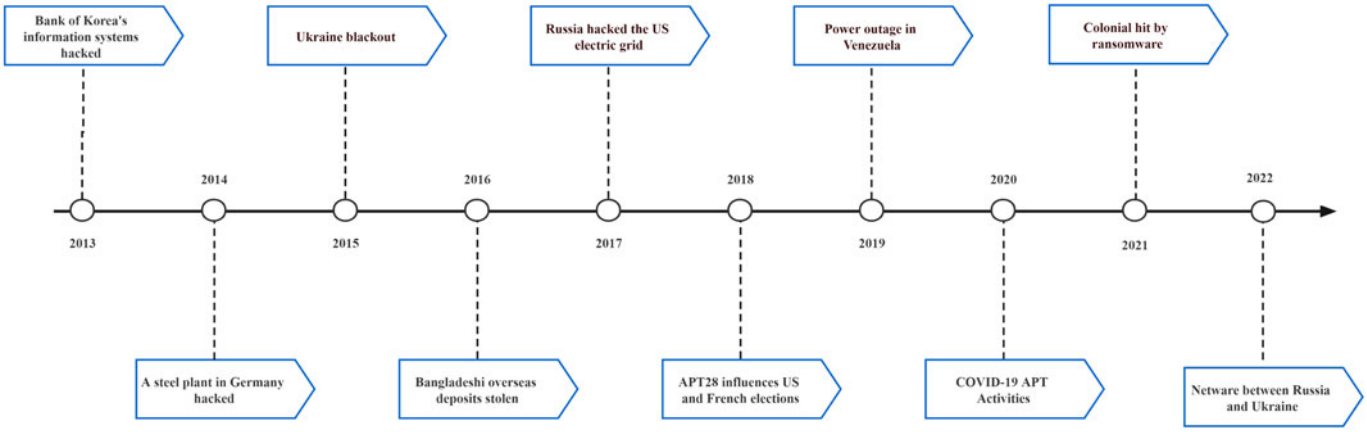


Fig. 1. Major APT attacks from 2013 to 2022.

confrontation [4]. Two forms of CTI currently exist. One is the structured indicators of compromise (IoC), which identifies potentially malicious activity on a system or network and can be directly used as evidence of malicious activity. Examples of IoC are hashes in malware samples or malicious IPs/domains. Another common form of CTI is the unstructured text open-source cyber threat intelligence (OSCTI) reports. OSCTI reports are in-depth analyses of APT attack events. However, the rapid growth of threat data has raised challenges for the use of OSCTI to defend APT as OSCTI reports are obtained from multiple data sources, which are featured by uneven quality, complex application scenarios, and highly unstructured natural language.

Many security researchers and groups have explored OSCTI reports that address unstructured text. Here, extracting entities [5], [6] and relationships [7], [8] from OSCTI reports is an important step. Thus, automated tools have been designed to extract attack information from OSCTI reports; the tools can automatically extract threat indicators or IoC from public sources that describe attack events to analyze CTI. Google launched a search engine service based on knowledge graphs on May 17, 2012[11]. After recent years of development, knowledge graphs are being gradually regarded as a new type of information system infrastructure [12]. Frameworks such as structured threat information expression (STIX) [13] and common attack pattern enumeration and classification (CAPEC)[14] greatly facilitate the sharing of CTI by security researchers while addressing the tedious and messy process of handling CTI data. However, most studies on entity extraction in knowledge graphs are based on English, whereas obvious differences exist between Chinese and English [15]. Meanwhile, it is difficult to update the labeling information of the IoC because of the growing threat information. Therefore, an important research direction is the repair of the IoC information labels and the interdependent relationships in OSCTI reports. However, only a few studies have investigated the application of attack information after its extraction and construction. In the research of APT attack scenarios, traceable graph attack detection (by learning the attack behavior) is gradually replacing anomaly detection (by learning the user's normal behavior through audit logs) as a more effective method. ATLAS[16] learned the sequence of attacking and non-attacking behaviors simultaneously and constructed attack events by associating entities with events. However, it is equally important to study the attribution of attack events compared with attack detection and inference using logs or provenance graphs in the field of APT attack detection. Without confirmation of the identity and behavioral biases of the threat actor, it is impossible to predict a similar occurrence.

To address the above problems, the Cyberspace Institute of Advanced Technology of Guangzhou University, in conjunction with Nsfocus PINGXING Laboratory and FUYING Laboratory, established CSKG4APT, a cyberspace threat modeling platform based on a knowledge graph. The model extracts relevant threat information entities by collecting and analyzing the description information and logical relationship of the APT attack organization in OSCTI. By combining STIX[13], CYBOX[17], and other threat intelligence standards, the group constructed an APT cybersecurity attribution knowledge graph. The entity extraction algorithm for bilingual CTI reports was designed to update knowledge in CSKG4APT. Finally, the diamond model and threat hunting were applied in CSKG4APT to propose a scheme of APT attack organization portrait tracking.

The main contributions of this study are as follows:

1. Strong knowledge representation ability. Cyber threat knowledge reflects cyber threat information in different languages and from multiple dimensions. We designed CSKG4APT, a cybersecurity threat modeling platform based on a knowledge graph, which can effectively fuse multidimensional knowledge elements and ensure a comprehensive analysis of various associations in APT threat knowledge. CSKG4APT is a cybersecurity knowledge graph model for APT organization attribution based on the theory of ontology and built through the collection and analysis of APT organization information in OSCTI; STIX[13], CYBOX[17], and other threat intelligence data standards are also incorporated. CSKG4APT shows a complete APT knowledge graph, which combines tactical sets (attack characteristics and models), weapon sets (threats and vulnerabilities of attack tools), and asset sets (high-risk and key assets) for an effective mapping of cybersecurity elements in CTI.

2. Automatic knowledge extraction. To update APT threat knowledge graphs, we proposed an algorithm to recognize threat knowledge using bidirectional encoder representations from transformers (BERT) for entity extraction from bilingual

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 1
List of Related Work

Fields	Categories		Publication
CTI	Standards of CTI		[14] [20] [18] [22] [21]
	Analysis of CTI	Statistical machine learning	[23] [24]
		Deep learning	[25] [26] [27] [28] [29] [30]
		NLP	[31] [32] [33] [34]
Construction and application of threat knowledge graph	Academic		[35] [36] [37] [38] [39]
	Commerce		[40] [41] [42] [43]
Cyber threat attribution	Based on CTI		[44] [45]
	Model design		[46] [59]
	Mathematical algorithm		[48]
	Social science		[49]
	Machine learning		[50] [51]

threat intelligence texts. Our algorithm was demonstrated to accurately identify relevant entities in bilingual threat intelligence texts, and the macro-average and micro-averages outperformed those of other algorithms used for comparison.

3. Meaningful practice. We utilized a knowledge graph to implement a set method of APT organization threat hunting. During the deployment, we applied CSKG4APT and cyberspace security big data to design an analysis engine and exploited the intrusion analysis diamond model[57] in CSKG4APT to profile the attacking organization. The test showed that the program facilitates the construction of cybersecurity defense capabilities.

The rest of this paper is organized as follows. Section 2 discusses the related work of CTI, construction of knowledge graph, and network threat attribution. Section 3 introduces the architecture of the cybersecurity knowledge graph based on APT OSCTI, including the design, construction, and application. Section 4 describes the data analysis and entity extraction algorithms as well as the application of attribution. Section 5 discusses limitations and future work. Finally, Section 6 summarizes the paper.

2 Related Works

Recently, researchers have conducted lots of studies on APT, CTI, and threat knowledge graph, which are summarized in Table 1 according to the fields and methods.

2.1 Cyber Threat Intelligence

CTI Standards. Many CTI standards and frameworks based on different demands have been established to facilitate the automatic generation and sharing of CTI. Examples of representative CTI standards are STIX[13], TAXII [19], CyBox [17], MISP[21], and OpenIOC [20].

CTI Analysis. Recently, security researchers and groups have attempted to automate the extraction of threat entities from open sources describing attack events. *Field of statistical machine learning*: Mulwad[22] *et al.* used support vector machine classifiers to extract concepts about vulnerabilities, attacks, and threats related to attacks. Joshi[23] *et al.* used a conditional random field (CRF) approach to identify and classify references to entities and concepts. *Field of deep learning*: In the published SemEval-2018, Manikandan[24] *et al.* used a CNN–CRF model to identify entities related to malicious software. Dionsio[25] *et al.* constructed a BiLSTM–CRF named entity recognition model to identify named entities from network security tweets on Twitter. Gasmi[26] *et al.* exploited an LSTM–CRF model to extract network security concepts and entities. Satyapanich[27] *et al.* designed CASIE, a system that uses the BiLSTM model and an attention mechanism for classifying cybersecurity entities. Li[28] *et al.* proposed an attention-mechanism-based BiLSTM–CRF model for the entity recognition of network security texts. HINCTI[29] proposed a heterogeneous graph convolutional network method based on MIIS measurement to identify the threat types of infrastructure nodes in CTI and to complete relevant IoC information. *Field of deep natural language processing (NLP)*: Liao[30] *et al.* developed iACE, a system that transforms the task of extracting IoC into a graph similarity problem. If an IOC has a similar graph structure to that of the training set, it is identified as a definite IoC, meaning iACE can automatically extract IoC from CTI and capture their context. Husari[31] *et al.* proposed TTPDrill, which uses NLP and information retrieval to extract threat actions from unstructured CTI text. Zhao[32] *et al.* designed TIMiner, an IOC extractor with domain labels, which can automatically extract IoC and corresponding domain (region information) labels in network security texts. Satvat[33] *et al.* proposed Extractor to automatically extract attack behaviors from CTI reports using NLP technology; the authors also exploited semantic role labeling for semantic analysis to understand the relationships among attack behaviors. Finally, the unstructured text is output in the form of a provenance graph.

2.2 Cybersecurity Knowledge Graph

The cybersecurity knowledge graph enhances the presentation of threat knowledge to enable security researchers accurately and efficiently obtain various threat information for preliminary intelligent decision-making.

In terms of academic research, Zhao[34] *et al.* defined different ontologies based on expert knowledge to describe the relationships between entities. Kiesling[35] built SEPSES knowledge graph (SKG), a knowledge graph for cybersecurity, and demonstrated how to generate security alerts from Snort and connect them to SKG for a deeper understanding of ongoing cyber threats. Deng[36] *et al.* constructed a knowledge graph of cybersecurity practices for students by leveraging big data and NLP techniques. Using the constructed knowledge graph, students can browse and search for

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

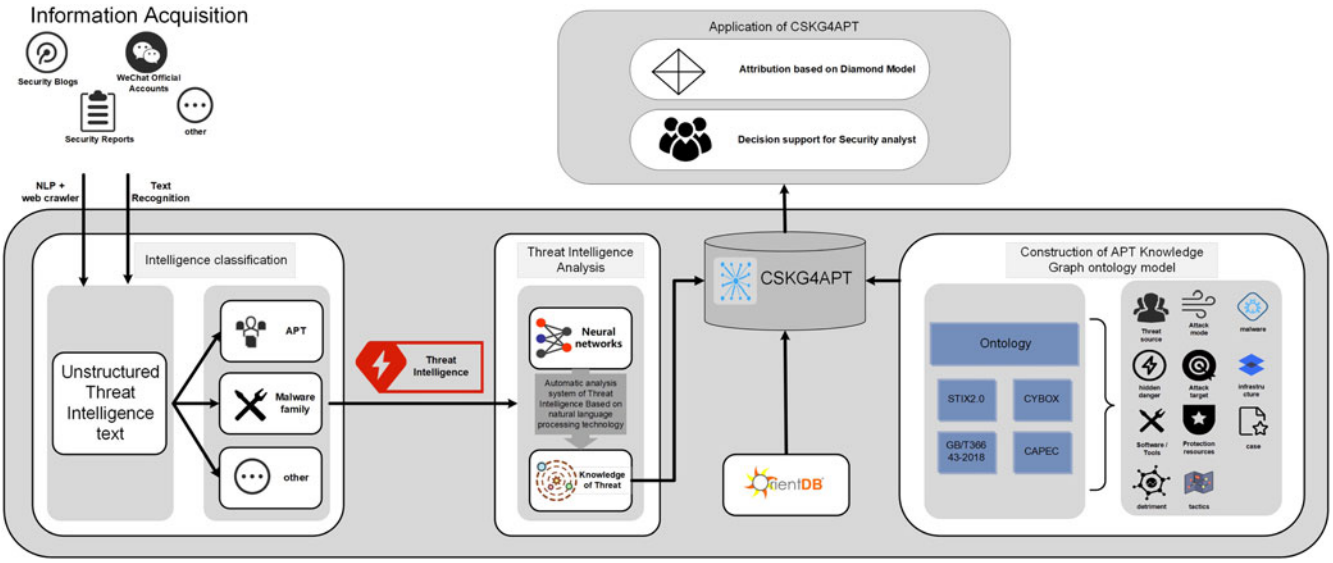


Fig. 2. Framework of CSKG4APT.

concepts related to cybersecurity and their interdependency. Du[37] *et al.* developed a knowledge graph-based and human-readable threat intelligence recommendation system, which is highly compact and comprises several features such as security items, network entities, and emerging hacker groups and attacks. Mozzaquator[38] *et al.* proposed an ontology-based network security framework for the Internet of Things. The framework, in terms of IoT knowledge reasoning, was used to monitor IoT devices, classify cyber threats or vulnerabilities, and take appropriate countermeasures to ensure the operation of existing services. In practical applications, enterprises and institutions have successively used knowledge graphs to launch proprietary threat intelligence analysis systems for different scenarios. Examples include IBM's X-Force Exchange[39], 360 Alpha Threat Analysis Platform[40], TianJi Partners' RedQueen Security Intelligence Service Platform[41], and Weibu Online[42].

2.3 Cyber Threat Attribution

The technology of attribution can not only assist security analysts in detecting advanced persistent threats, but can also establish a connection between threats from different attack events. Noor [43]*et al.* extracted high-level IoC from CTI documents; converted the IoC into a CTA–TTP correlation matrix, which is used as the input of the classifier to train the model; and made predictions and attributions. Qiang[44] *et al.* proposed a network attack attribution framework based on threat intelligence, which achieves a certain accuracy in the attribution results. The triangle model proposed by Warikoocite[45] *et al.* performs the attribution of an attack by extracting and comparing three indicators (sector, tools, TTPs) for credible results. Hettema[47] *et al.* analyzed the cognitive state from a philosophical perspective to reduce the cognitive load during attribution while improving the reliability of the attribution results. Sahoo[48] *et al.* extracted features from the perspectives of malware opcode, bytecode, and header and trained multiple machine learning algorithms to build a multi-perspective heuristic analysis model. Belaoued[49] *et al.* proposed a machine learning-based heuristic analysis method that utilizes the application programming interface and technical PE features invoked by malware programs to classify malware files.

3 System Architecture

The overall architecture of CSKG4APT consists of four parts: information acquisition, threat intelligence analysis, construction of threat knowledge graph model, and application of CSKG4APT for APT attack organization attribution. The architecture is illustrated in Fig. 2.

Through CSKG4APT, a unified language can be established to describe the behavior and characteristics of different APT organizations. The system also contains the construction of a knowledge base for APT organizations as well as knowledge updates. Moreover, to comprehensively understand the attackers and their behavioral biases and consequently design effective defensive measures, CSKG4APT can be used for attack simulation, tracking of known attacking organizations, and identification of unknown attacking organizations. Each of these is described in detail below.

3.1 Construction of Cybersecurity Knowledge Graph

The field of cyber threat intelligence and related security elements have many relatively mature standard systems, such as the structured threat information expression (STIX) [13]. For specific security elements, the corresponding standard specifications are: common attack pattern enumeration and classification (CAPEC) [14], malware attribute enumeration and characterization (MAEC) [53], common vulnerabilities & exposures (CVE)[54], etc.

Since the data source of this study is an unstructured text report collected from various sources, the knowledge type is improved. CSKG4APT focuses on attacking organizations (such as APT organizations, malicious code families) and implements a set of APT organization portrait tracing schemes through the knowledge of the organization's technical level (attack tools, attack methods, vulnerabilities, malicious samples), network infrastructure (IP, domain,

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

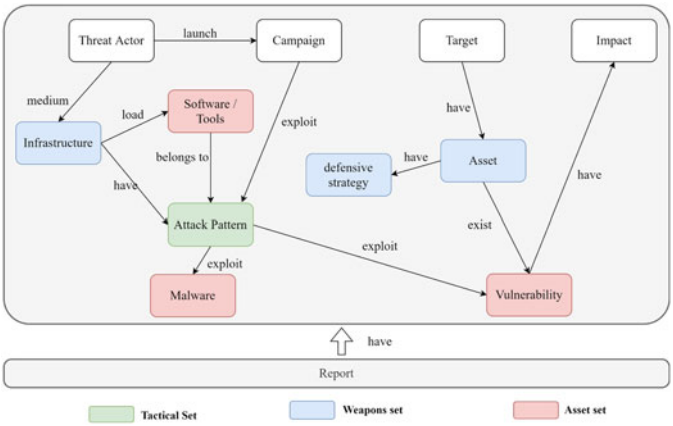


Fig. 3. Ontology structure of CSKG4APT.

email), historical campaign, characteristics of the attack target, and harm intentions.

The settings of various security entities involved in the attacking organization mainly refer to the above-mentioned mature security element specifications. The design of entity relationship mainly refers to the object association in STIX 2.0, and the constructed graph ontology structure is shown in Fig. 8. In particular, to learn the attacking preferences of attacking organizations in the campaign, we utilized the knowledge graph and performed a more comprehensive construction for CSKG4APT. On the basis of the four ontologies of the attacker, campaign, target, and influence from the cognitive level, CSKG4APT supplements the sets of tactics, weapons, and assets:

- Tactical set: attack pattern
- Weapons set: software/tools, malware, vulnerabilities
- Asset set: infrastructure, defensive strategy, asset

Using the tactics, weapon, and asset sets, CSKG4APT established a connection between attacks and assets as well as the correspondence with tactics while summarizing the attacking preferences of the attacking organization.

3.1.1 Type of Entity

The construction of threat entities comprises two parts: knowledge type design and dictionary specification definition. Knowledge type design limits the content range of knowledge graph description, and the knowledge graph proposed in this study is limited within APT. Dictionary specification restricts the attribute description of knowledge to unify the expression.

Knowledge Type Design. Fig. 3 illustrates 12 knowledge types defined in CSKG4APT: Attacker, Attack pattern, Malware, Vulnerabilities, Target, Infrastructure, Software/tools, Assets, Campaign, Impact, Defensive strategy, and Reports. Table 2 details the knowledge types. Each knowledge type contains several sub-classes. For example, "Attacker" contains "threat_actor" and "organization"; "Malware" contains "Backdoor_tools," "Dropper_tools," and "Exploit_tools."

Dictionary Specification. As a description constraint of different types of knowledge attributes, dictionary specification facilitates the unified expression and understanding of knowledge and is also the standard of external data fusion disambiguation. The dictionary specification is intended to describe the properties of the type of knowledge; it also refers to STIX and various security standards.

Given a knowledge type, the following definitions are given according to attack information extracted from OSCTI:

Case 1: Software/tool is a set of attack tools with ten types, which is defined as:

$$\exists Software/Tool \subseteq \forall(adware \cup backdoor \cup ... \cup Trojans) \quad (1)$$

Case 2: Attacker, which includes identity, role, technical level, resource level, and motivation, with a total of 40 description norms is defined as:

$$\begin{aligned}\exists Attacker \subseteq \forall Identity(hacker \cup insider \cup \cdots) \cap \\ \forall Role(proxy \cup \cdots \cup head) \cap \\ \forall Techlevel(minimal \cup advanced \cup \cdots \cup strategic) \cap \\ \forall Resourcelevel(individual \cup club \cup \cdots) \cap \\ \forall Motivation(accidental \cup coercion \cup \cdots) \quad (2)\end{aligned}$$

3.1.2 Type of Relationship

The definition of knowledge type forms isolated knowledge nodes with information describing the characteristics of the APT organization. No semantic relationship exists between knowledge nodes; hence, it is impossible to perform semantic search and inference analysis of the APT organization. The CSKG4APT ontology structure summarizes a set of semantic relations suitable for the APT organization

TABLE 2
Knowledge Types

Knowledge Types	Explanation
Attacker	Attack initiator (individuals, groups, or organizations)
Attack_pattern	Threat actor through tactics, technologies, and programs
Malware	Malicious software or script-related attack actions
Vulnerability	Misconfiguration and software vulnerabilities that can be exploited by threat actor
Target	Target Assets
Infrastructure	Identification of the network facility that initiates the attack (IP, domain, email)
Software/tools	A legitimate software tool deployed on a specific terminal
Assets	Security device resources that provide specific defense capabilities
Campaign	A series of threats directed at specific victims
Impact	Possible security threats and losses caused by targeted attacks
Defensive strategy	Defensive strategy
Reports	Event analysis for specific attack organizations

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 3
List of Relationship Types

Source	Target	Relationship	Explanation
Threat Actor	Campaign	launch	Indicates that the threat actor has launched a campaign
Threat Actor	Infrastructure	medium	Indicates that the threat actor is using the infrastructure as a medium
Infrastructure	Tools	load	Indicates that the infrastructure is loaded with software and tools
Infrastructure	Attack Pattern	have	Indicates that the threat actor designs attack patterns through the infrastructure
Tools	Attack Pattern	belongs to	Indicates that the software and tools belong to Attack Pattern
Attack Pattern	Malware	exploit	Indicates that the threat actor mode exploits malware
Attack Pattern	Vulnerability	exploit	Indicates that the threat actor mode exploits vulnerability
Target	Asset	have	Indicates that the attack target is assets
Asset	Defensive	have	Indicates that the asset has a defense strategy
Asset	Vulnerability	exist	Indicates that the asset has vulnerability
Vulnerability	Impact	have	Indicates that the vulnerability has an impact

analysis by extracting the analysis techniques and clue logic relations mentioned in the APT report.

We take a report, "APT28: AT THE CENTER OF THE STORM"[55], published by FireEye as an example. The report analysis shows that APT 28 exploits CVE-2015-1701, CVE-2015-2424, CVE-2015-2590, CVE-2015-3043, and other vulnerabilities to affect Flash, Java, and Windows. The analysis uses logical relationships derived from the US National Vulnerability Database (NVD) [56], which contains expert knowledge CVE_ID (Vulnerability) "affecting" CPE_ID (Asset). NVD also contains CAPEC_ID (Attack Pattern) "exploiting" CWE_ID (Vulnerability), CVE_ID (Vulnerability) "belonging to" CWE_ID (Vulnerability), and other logical semantics belonging to expert knowledge.

Moreover, seven relationship types are defined in the structured APT report published by STIX [13]: targets, uses, indicates, mitigates, attributed-to, variant-of, and impersonates. The relationship types realize the connectivity of 12 object domains. Inspired by STIX's [13] Intelligence Correlation and International Vulnerability Database (NVD) [56], we designed CSKG4APT with seven semantic relations: "load," "exploit," "launch," "have," "belongs to," "exist," and "medium," as presented in Table 3.

Each relationship type contains several sub-classes. For example, "Load" contains "load_driver," "load_library," and "load_to_sys"; "belongs to" contains "similar_to," "related_to," and "belongs_to"; "exist" contains "utilize_weakness" and "install_on_to."

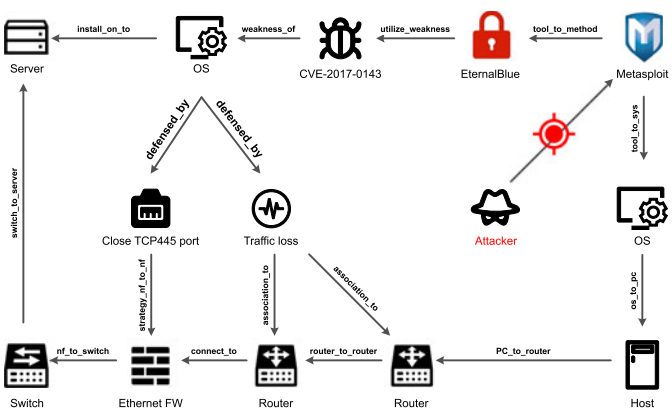


Fig. 4. A sample vulnerability attack on EternalBlue.

3.1.3 Case

In the actual scenarios, it is necessary to detect a threat ontology in the knowledge system, such as SMB remote code execution vulnerability (CVE-2017-0143). Through the semantic relationship established by the knowledge graph and the asset information (server, firewall, router), the affected assets (server) are output and relevant disposal suggestions (close port 445, traffic discard) are recommended. In addition to acquiring situational information, the threat impact and possible defensive measures are considered. An example of EternalBlue is illustrated in Fig. 4.

3.2 Collection and Analysis of Threat Information

Since a large amount of advanced threat intelligence currently exists in unstructured text, CSKG4APT first constructs highly scalable intelligence feeds through intelligence feed configuration templates. Subsequently, intelligence related to attackers is filtered while irrelevant data are removed. Finally, multiple threat intelligence types are automatically extracted by combining knowledge base and NLP technology.

The above method is implemented through three main functional modules: 1) Collection of original information, 2) Distinction of intelligence topics, and 3) Automated extraction of threat intelligence. To achieve high scalability, a general collection configuration template is established in the module of original intelligence collection through the analysis of unstructured intelligence data sources. To filter irrelevant data in intelligence sources, the intelligence topic distinguishing module takes the attacker as the core and identifies and distinguishes the original intelligence related

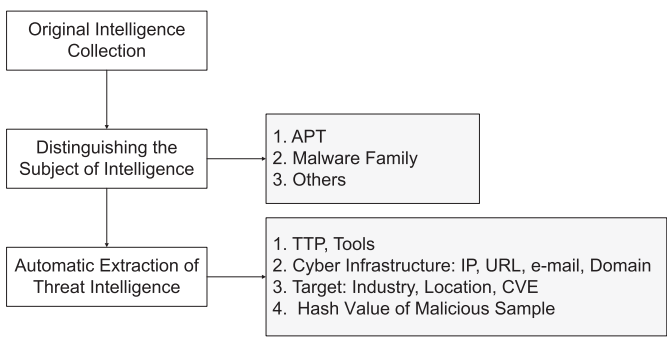


Fig. 5. Information collection and analysis.

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

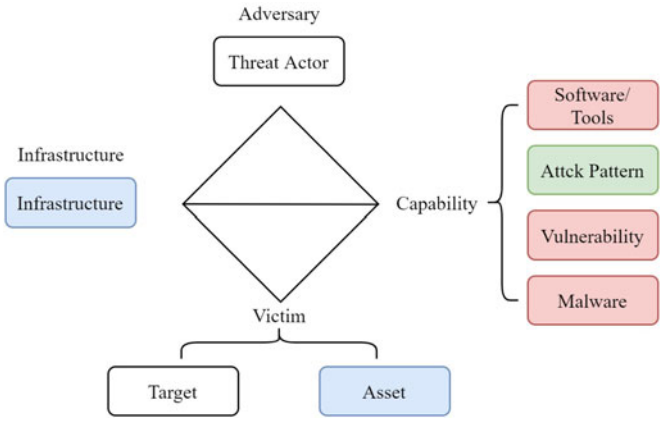


Fig. 6. Construction of APT organization attribution.

to the APT organizations and malicious code families. The automatic extraction module of threat intelligence combines the existing standard knowledge base of the attack technology means and NLP technology to extract basic and advanced threat intelligence automatically. The implementation process is illustrated in Fig. 6.

3.2.1 Information Acquisition

In this module, CSKG4APT mainly generates a crawler file by configuring the data source, selecting the corresponding template, inputting the specified configuration items, and debugging. Meanwhile, the module of information acquisition module uses multiple middlewares to improve the crawling performance of the crawler for fast and high-compatibility crawling. This module eventually outputs structured data and unstructured raw report documents as HTML files.

The crawler framework is optimized and improved using the Scrapy–Redis framework [50]. The crawler framework greatly improves the flexibility of the crawler through the interactive use of the engine, scheduler, downloader, crawler, pipeline, and middleware. The cumbersome, redundant code writing is also simplified, and repeated requests can be reduced by combining Redis for fingerprint deduplication. This method improves the overall performance and usability of the crawler through the following middleware.

1) *Proxy Middleware*. When the client frequently sends requests to the server, the server collects the IP behavior and access frequency to identify and prohibit the crawler from running. Therefore, the CSKG4APT dynamic IP proxy middleware places the acquired dynamic IP in the Redis database and randomly obtains the dynamic IP from the locally built IP pool web application interface to avoid being banned because of excessively fast access.

2) *Headers Middleware*. Generally, the server not only identifies the client type from the IP, but also judges it based on the request header. To better crawl server information, a request header middleware is written according to the real request header specification, which is used to simulate the process of various browsers initiating requests. CSKG4APT refers to the open-source libraries, modifies the request headers for different websites and request failures, and disables the request header settings in the Scrapy download middleware.

3) *Retry Middleware*. Many errors may occur from the point of sending a request to the point of receiving the returned data. According to the application scenario, CSKG4APT has a retry middleware, which is configured to reattempt a request when certain responses are received and stop attempting when the attempts of a certain resource reach a certain threshold. The original Intelligence collection processing is shown in Algorithm 1.

Algorithm 1. OICP

```
while True do
  url = getNext(url _ queen)
  flag = isInRedisFingerprint(url)
  if flag is Flase then
    break
  end if
FLAG:
  data = addRandomHeadinfo(url)
  ip = getDynamicIP()
  response = sendRequest(ip, data)
  if isTimeout(response) || isInRetryList(response) then
    if reachedThreshold() then
      return ErrorInfo
    end if
    go to FLAG
  end if
end while
getData(response)
```

3.2.2 Classification of Intelligence Topics

Since the data collected from the data source may contain irrelevant information, such as recruitment information and product promotion information published by websites/self-media, it is necessary to subject the unstructured data (i.e., HTML files) to differentiated processing that can speed up subsequent intelligence information extraction. CSKG4APT has a designed topic classification method based on word segmentation technology, which can parse and extract text from HTML files and correlations based on a self-built dictionary. The collected text is classified into three categories: topics about APT attack organizations, topics related to malicious code families, and others. CSKG4APT Intelligence Subject Distinguishing Processing (ISDP) is shown below as Algorithm 2.

Algorithm 2. ISDP

```
htmlData = analysis(HTML)
if IOC not in htmlData then
  return Other
end if
data = segmentation Processing(htmlData)
map_result = map To Dictionary(data, default Dictionary)
if map_result is Null then
  return Other
end if
if APT_weight > Malware_weight then
  return APT
else
  return Malware
end if
```

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

3.2.3 Automated Extraction of Threat Intelligence

The module of automated extraction of threat intelligence takes the original report as input and uses the normalized text cleaning method to clean and respond to the hidden threat intelligence in the input text. The module then combines targeted regularization and named entity recognition technology to extract threat intelligence. The extracted intelligence types are IP, domain, URL, vulnerabilities, attack techniques, sample hashes, etc. Subsequently, NLP technology is used to identify attackers, software tools, geographic information, attack targets, and other information. Finally, formatted threat intelligence data are output.

Analysis and research on original reports from different sources showed that the extracted original report content text (HTML/PDF) contains wrong line breaks and advertising content, which interfere with the extraction of threat intelligence. Therefore, to improve the accuracy of automated threat intelligence extraction, the following cleaning is required:

- Remove special symbols on the left or right side of "." "@," "/," and "//";
- Transform the keywords "hxxp" and "hxxps";
- Record specific keywords, such as "contact us," related to the recommendation and exclude the information immediately following these keywords; and
- Interrupt index construction for keywords related to the end of the article (such as "about us," "team introduction") to exclude the fetch errors due to ad content.

Afterward, the module identifies and extracts common basic threat intelligence through regular expressions, including IP, domain, email, URL, hash, CVE, and ATT&CK. For cyber threat intelligence texts, to provide strong support for source tracing and system defense, CSKG4APT has a threat intelligence named entity recognition system CTI View[51] based on BERT [52]. Unlike English CTI reports, Chinese CTI contents are segmented by words and punctuation because of the particularity of the Chinese language. The CTI View first inputs the labeled data into the BERT layer and then obtains a pre-trained model and the word vector. Subsequently, the word vector is input into the BiLSTM, GRU, and CRF modules in turn for processing. Finally, five entities of attackers, software/tools, industries, regions, and campaigns are extracted, and the proposed method is evaluated on the dataset.

3.3 APT Organization Attribution

In the past few years, unlike the traditional cyber threat attribution with query and association as the core, CSKG4APT uses the knowledge graph and big data of network space security to design a targeted big data analysis engine. The engine is based on expert knowledge supplemented by artificial intelligence and is for conducting clue-based reconnaissance and investigation. It uses the diamond model to attribute APT organizational portraits to generate more intelligence. The model facilitates the construction of strategic deterrence and defense capabilities in cybersecurity.

The diamond model was proposed by Caltagirone[57] in the article, "The Diamond Model of Intrusion Analysis," in 2013. The model describes the opponent using infrastructure deployment capabilities for victims, which contain four basic elements.

- Adversary: An adversary is the actor/organization responsible for utilizing a capability against the victim to achieve their intent.
- Victim: A victim is the target of the adversary and against whom vulnerabilities and exposures are exploited and capabilities used.
- Capability: The capability feature describes the tools and/or techniques of the adversary used in the event.
- Infrastructure: The infrastructure feature describes the physical and/or logical communication structures the adversary uses to deliver a capability, maintain control of capabilities (e.g., command-and-control/C2), and effect results from the victim (e.g., exfiltrate data).

In this study, the diamond model is extended, and the huge data support of CSKG4APT is used to sketch different attack events launched by APT attack groups. A portrait of the prototype diagram is presented in Fig. 6.

4 Experiments

No mature and complete APT threat corpus exists in the field of APT yet. Therefore, CSKG4APT collects the APT-shared threat report through the method described in Section 3.2. Many researchers on our team also collect corpus from different dimensions under the knowledge map framework proposed in Section 3.1 through various ways, and they use the knowledge map technology to generate knowledge. CSKG4APT uses the knowledge graph as the data representation, orientDB as the storage database, and multiple built-in data types as the data storage format. A total of 2,608,327 knowledge nodes and 1,2935,201 connection relationships were constructed in this study.

4.1 Data Analysis

We currently found 378 APT attack groups through OSCTI. A total of 1,041 CTI reports from 215 attack organizations were randomly selected as the samples of this experiment. The analysis showed that Lazarus Group and Sofacy had the most reports, with 100 and 95 CTI reports, respectively, out of the 1,041 CTI reports. The data contains 25 APT organizations with ten or more CTI reports, accounting for more than 60% of the total number of reports. In the cybersecurity knowledge graph of CSKG4APT, we conducted a visual analysis of the knowledge graph data from four perspectives: location of the APT organization, region of the attacked target, industry involved in the attack, and motivation of the attack. We anonymized some of the information in this experiment.

As illustrated in Fig. 7a, the number of APT organizations that cannot be determined by region was the highest because of advanced attack techniques or the mutual imitation or organizational changes of APT organizations. The number of APT organizations in other regions decreased. More APT

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

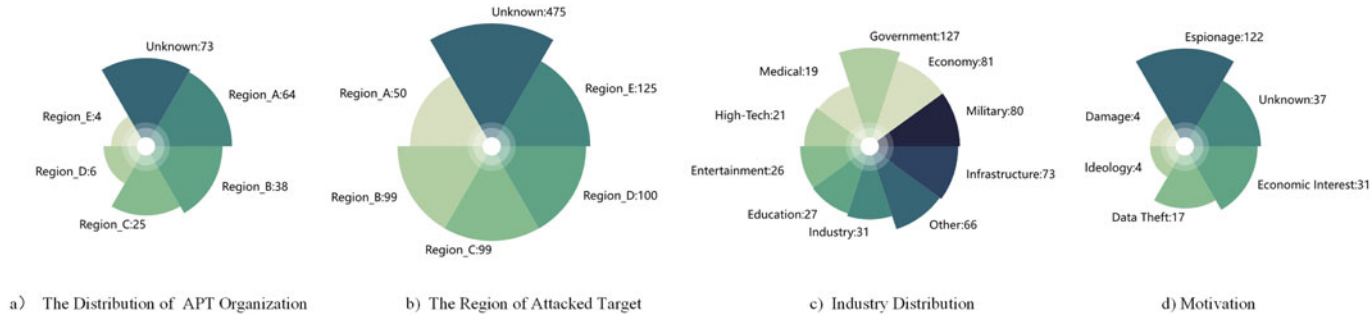


Fig. 7. Correlative features of APT organization in CSKG4APT.

organizations were disclosed in Region_A, Region_B, and Region_C. Unlike the protection of victim information or the starting point of writing, the attack target of Unknown classification was the most among the collected reports according to OSCTI. Unlike the performance in Fig. 7a, all regions were plagued by APT attacks, and the distribution of the region of the attacked target was relatively average. Industry distribution: Fig. 7c shows that APT attacks occur in various fields; the critical areas include government, finance, military, and infrastructure, followed by industry, education, entertainment, healthcare, and other important sectors. The motivation of the attack: As shown in Fig. 7d, the main purpose of APT organization attacks, according to the CTI reports, includes espionage, economic interests, data theft, ideology, and destruction, excluding attacks with unknown intentions. APT attacks tend to be highly and more profitably organized than those performed by single hackers or small groups for economic reasons or pleasure.

To obtain a clearer understanding of the weapon set of each APT attacking organization, we use Fig. 8 to display the Software/Tools used by the 25 APT organizations with the most reports in CSKG4APT. Shamoom is a prominent APT organization among the 1,041 reports. However, the Software/Tools used by Shamoon were not collected; hence, it does not appear in Fig. 8. As can be seen from Fig. 8, different APT organizations have different preferences for Software/Tools. The ratio of APT organization reports from Lazarus Group and Sofacy to all reports is 18.73%, but the Software/Tools used by Lazarus Group and Sofacy are fewer. Gamaredon Group has better use of Software/Tools in CSKG4APT. The more capable APT organizations have a strong ability to imitate Software/Tools, and Software/Tools are undisclosed in OSCTI because of the advanced technical skills of the APT organizations.

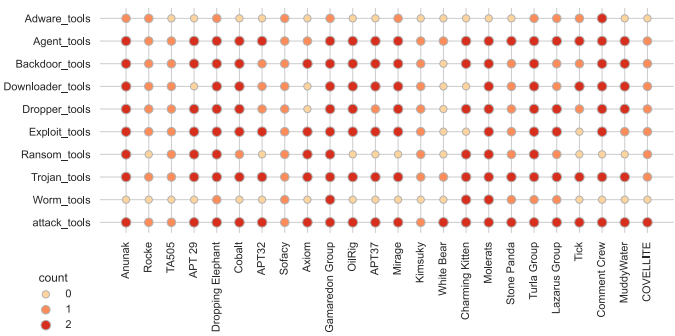


Fig. 8. Software/Tools of weapon set used by 24 APT organizations.

4.2 Entities Extraction Experiment

As there is not yet a mature and complete corpus of APT threat intelligence in the field of named entity recognition, we collected APT shared CTI reports using the methodology described in Section 3.2. The data sources include APT threat intelligence published regularly by over 20 cybersecurity vendors. This experiment focused on CTI reports in English and Chinese. A total of 120 English APT CTI reports and 100 Chinese APT CTI reports were assigned to the training set, validation set, and test set in the ratio of 8:1:1.

4.2.1 Evaluation Metrics

We referred to the standard of ATT&CK and used the tool YEDDA[58] to perform sequence labeling according to the BIO labeling format. Our proposed model extracts multiple entities; thus, its use is based on traditional evaluation metrics. Precision (P), Recall (R), F1-score (F1), macro-average ($P_{marco(F1)}$), and micro-average ($P_{micro(F1)}$) were used for evaluating the entity extraction performance. The macro-average is the arithmetic mean of the performance of each entity, whereas the micro-average is the arithmetic mean of the performance of the reports. Equations (3)–(8) show the calculation method of micro-average and macro-average.

$$P_{marco(P)} = \frac{1}{n}\sum_{i=1}^{n}\left(\frac{TP}{TP+FP}\right)_i \tag{3}$$

$$P_{marco(R)} = \frac{1}{n}\sum_{i=1}^{n}\left(\frac{TP}{TP+FN}\right)_i \tag{4}$$

$$P_{marco(F1)} = \frac{1}{n}\sum_{i=1}^{n}\left(\frac{2TP}{2TP+FN+FP}\right)_i \tag{5}$$

$$P_{micro(P)} = \frac{\sum_{i=1}^{n}(TP)_i}{\sum_{i=1}^{n}(TP)_i + \sum_{i=1}^{n}(FP)_i} \tag{6}$$

$$P_{micro(R)} = \frac{\sum_{i=1}^{n}(TP)_i}{\sum_{i=1}^{n}(TP)_i + \sum_{i=1}^{n}(FN)_i} \tag{7}$$

$$P_{micro(F1)} = \frac{2P_{micro(P)}P_{micro(R)}}{P_{micro(P)} + P_{micro(R)}}. \tag{8}$$

4.2.2 Experimental Results

The typical BERT-based NER models and our proposed model were trained and tested on the corpus. Tables 4 and 5 present a comparison of the experimental results for English CTI reports of the different algorithms under the macro and micro evaluation metrics. Tables 6 and 7 present a comparison of the experimental results for Chinese CTI reports of

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 4
Comparison of Experimental Results of English CTI Reports Using Macro-Average

Models	Macro		
	Precision	Recall	F1
BERT_LSTM	72.79%	59.59%	65.53%
BERT_BiLSTM	73.56%	66.35%	69.59%
BERT_BiLSTM_CRF	76.36%	68.80%	72.13%
Our_Method	77.67%	69.74%	73.20%

TABLE 5
Comparison of Experimental Results of English CTI Reports Using Micro-Average

Models	Micro		
	Precision	Recall	F1
BERT_LSTM	72.13%	59.59%	64.96%
BERT_BiLSTM	74.24%	66.35%	70.07%
BERT_BiLSTM_CRF	76.89%	68.80%	72.62%
Our_Method	78.52%	69.74%	73.87%

TABLE 6
Comparison of Experimental Results of Chinese CTI Reports Using Macro-Average

Models	Macro		
	Precision	Recall	F1
BERT_LSTM	57.62%	70.46%	62.59%
BERT_BiLSTM	69.58%	80.15%	74.25%
BERT_BiLSTM_CRF	75.78%	78.45%	76.42%
Our_Method	82.07%	82.08%	81.88%

the different algorithms under the macro and micro evaluation metrics.

First, our proposed model outperformed the other models as it achieved the best score of 81.88 in both macro and micro metrics for Chinese CTI reports. Our model also outperformed other models in the English CTI reports. Second, the BiLSTM uses a bi-directional structure to obtain contextual sequence information, and the CRF module can utilize the correlation of similar labels to obtain contextual information. Our model has an additional GRU layer between the BiLSTM and CRF layers, increasing its depth to extract features at a deeper level. This structure makes the model comparable to BERT_BiLSTM_CRF, with 1.1% and 5.46% improvement in both $P_{macro(F1)}$ and $P_{micro(F1)}$. Finally, we compared the performance of different entities extracted using different models; the results are shown in Figs. 9 and 10. In the English CTI reports, the overall result of extracting the entities campaign was less satisfactory than that of other entities, and the extracted entities obtained a higher score in the Chinese CTI reports.

4.3 APT Organization Attribution

In this subsection, four APT organizations are selected from the knowledge graph as examples, and one is described in detail. Attributing the attack organization diamond model

TABLE 7
Comparison of Experimental Results of Chinese CTI Reports Using Micro-Average

Models	Micro		
	Precision	Recall	F1
BERT_LSTM	54.91%	70.46%	61.72%
BERT_BiLSTM	68.96%	80.15%	74.13%
BERT_BiLSTM_CRF	74.48%	78.45%	76.42%
Our_Method	81.69%	82.08%	81.88%

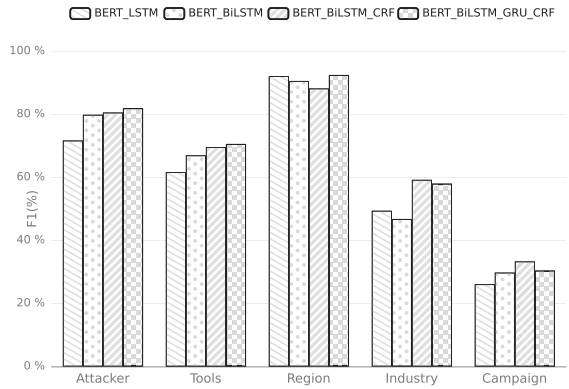


Fig. 9. Results of different entities extracted in English CTI reports.

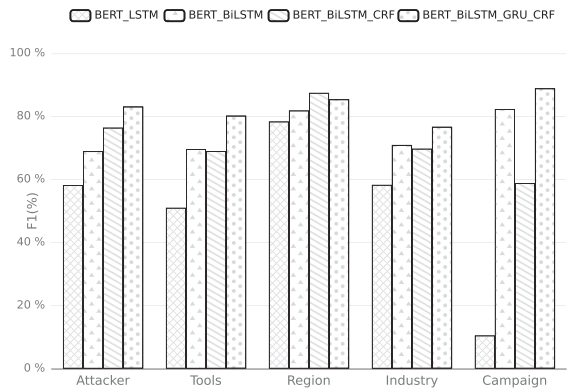


Fig. 10. Results of different entities extracted in Chinese CTI reports.

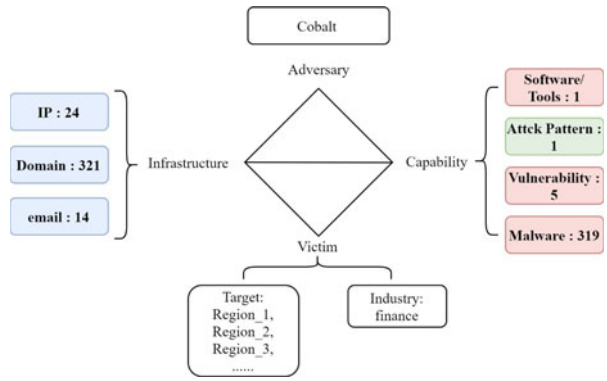
to previous attack events can assist security analysts in decision-making.

4.3.1 APT Organization Hunting

Currently, the region attribution of APT organizations has high complexity. Approximately 65% of APT organizations failed to make effective country attribution. Thus, the attribution evidence disclosed in some reports was insufficient; moreover, the possibility of misjudgment and imputation also exists. An analysis of the historical attack industry of APT organizations (excluding organizations without a specific attack industry) shows that the government attracts the greatest attention from APT organizations, and approximately 51% of APT organizations perform data theft, latency, and other espionage activities against the government. Furthermore, research, education, operators, and other fields

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 8
Cobalt

Organization	Cobalt				
Alias	Cobalt group Cobalt Group Cobalt gang Cobalt Gang GOLD KINGSWOOD Cobalt Spider			
Industry	Financial			
Disclosure	2016/10/5			
Recently active	2020/10/6			
Motivation	Economic interest			
Knowledge associated				
Report	IoC	Infrastructure	Malicious samples	Vulnerability
25	794	404	360	31
Recent reports				
2021/10/18	Harvester: Nation-state-backed group uses new toolset to target victims in South Asia			Alienvault
2020/12/29	Virus author uses crack to advertise Tencent video gimmick delivery CS backdoor			anquanke

are closely related to national security. APT organization files are based on the diamond model and comprehensively describe the characteristics of attack groups from the perspective of attack technology (malicious code, tools, vulnerabilities), network infrastructure (IP, domain name, mailbox, URL), attack target characteristics (industry, geography), home location, historical campaigns, etc. The four examples of APT organizations are as follows.

Table 8 shows that Cobalt performed simultaneous ATM robberies in multiple countries, including Europe, the Commonwealth of Independent States, and Malaysia. CSKG4APT found 25 OSCTI reports about Cobalt, 794 threat indicators, 403 network infrastructures, 360 malicious samples, and 31 exploits.

Table 9 shows that TA505 has been active since at least 2014 and is the behind-the-scenes developer of Drivex (banker Trojan) and Locky (ransomware). TA505 delivered malware through the botnet; other malware associated with TA505 include the ransomware of Philadelphia and Globe-Imposter. Through knowledge association discovery, we obtained 97 OSCTI reports, 5797 threat indicators, 3150 malicious samples, and four exploited vulnerabilities about TA505, which is one of the APT organizations with the most CTI reports in CSKG4APT.

Table 10 shows that the Silence group is attributed to an APT organization. According to various CTI reports, the group mainly targeted banks in Russia but now it targets more than 25 countries globally; at least one member of the group appears to be a former or current employee of a cybersecurity company. Only four related OSCTI reports were found in CSKG4APT, including 121 threat indicators, 17 malicious samples, and 101 exploited.

Table 11 shows that Anunak (also known as Carbanak) is attributed to a cyber criminal gang. Since 2013, the gang has launched attacks on 100 banks, electronic payment systems, and other financial institutions in about 30 countries and regions globally. Relevant attacks launched by Anunak are still active.

4.3.2 Case Study of APT Attribution

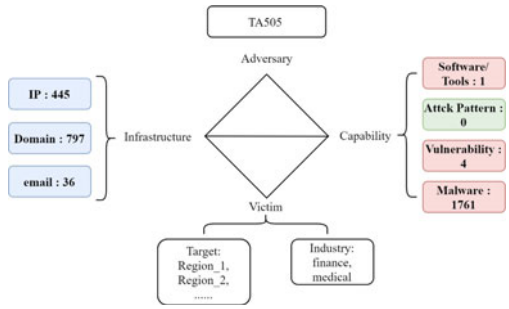
The following is a case study of the Anunak organization mentioned above. The aliases of the organization are FIN7, Carbanak Group, or Navigator Group Kolpakov. CSKG4APT collected 72 reports on Anunak from OSCTI and captured 4,644 Anunak-related threat indicators, 2168 network infrastructures, 2471 malicious samples, and five exploits. A total of 25 OSCTI reports of Anunak were included in this experimental sample. The analysis of the captured documents using decoy images showed that an earlier sample (md5: dc7c07bac0ce9d431f51e2620da93398) carried a unique Trojan. . This sample was first discovered on June 29, 2021. The Trojan has been used by FIN7 and TA543, according to security vendor Proofpoint. FIN7 mainly used the JSSLoader Trojan program to download the Trojan of Carbanak and Griffon. Proofpoint [60] published a report of a detailed analysis of the evolution process of the JSSLoader.

The JSSLoader Trojan in this example is connected to the C&C at https://crafterband.com, and the corresponding IP was 109.234.37.173. The Trojan that appeared in this phishing attack was a newer version of the known Trojan Griffon from FIN7. The countermeasures and other characteristics exhibited by the attackers in this incident were consistent with those of FIN7 in previous attack incidents, including the large-scale decoy delivery and use of common decoy images. These decoy documents using the topic of Windows 11 were part of the phishing attack recently launched by FIN7.

FIN7 is an advanced, finance-targeting APT attack organization whose activities started in 2015. The organization has historically targeted retail, restaurant, and hospitality

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 9
TA505

Organization	TA505	
Alias	SectorJ04 Group GRACEFUL SPIDER GOLD TAHOE	
Industry	Finance Healthcare	
Disclosure	2019/1/14	
Recently active	2021/10/21	
Motivation	Economic Interest	

Knowledge associated				
Report	IoC	Infrastructure	Malicious samples	Vulnerability
97	5797	2643	3150	4

Recent reports		
2021/10/21	MirrorBlast and TA505: Examining Similarities in Tactics, Techniques and Procedures	alienvault
2021/10/14	Explosive New MirrorBlast Campaign Targets Financial Companies	morphisec
2021/4/13	Threat Assessment: Clop Ransomware	Unit42
2021/2/23	Return of the MINEBRIDGE RAT With New TTPs and Social Engineering Lures	zscaler
2020/12/23	Clop ransomware	cybereason

companies with elaborate spear-phishing campaigns in the initial access. Once the victim's network is invaded, the group uses a behavior similar to that of APT to maintain and expand foothold until they accomplish their goals or gain access to unauthorized information.

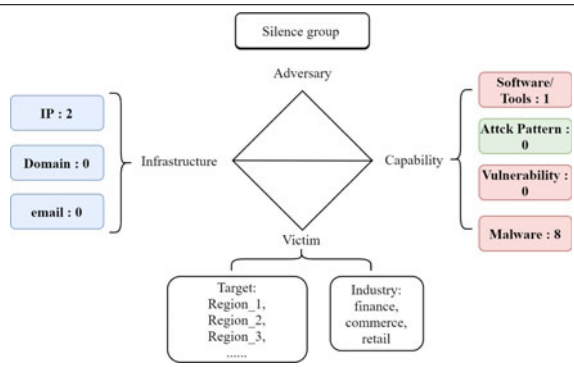
FIN7 has launched a highly sophisticated malware campaign against more than 100 companies since 2015. The organization hacked into thousands of computer systems and stole millions of customer credit and debit card numbers, which they then sold for profit.

FIN7 is a massive cybercriminal organization, and Kaspersky's public content in 2019 and 2020 showed that the group is still conducting cybercrime activities after losing its leader; they even pose as a penetration testing company and recruit hackers on a large scale.

5 Limitation and Future Work

CSKG4APT constructs 12 node types and seven edge types in the APT scene of CTI according to OSCTI and threat

TABLE 10
Silence Group

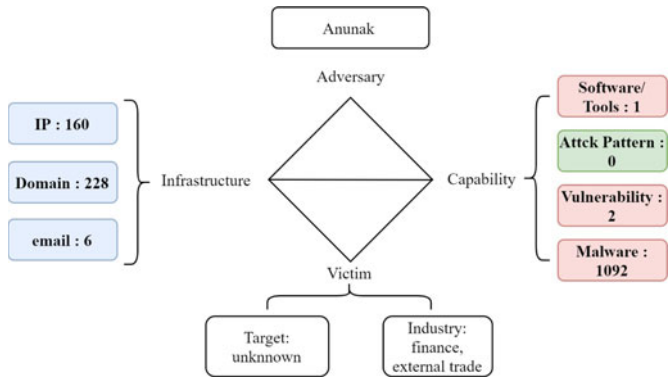
Organization	Silence group	
Alias	Silence Silence APT Organization WHISPER SPIDER	
Industry	Finance Commerce Retail	
Disclosure	2017/12/26	
Recently active	2019/8/21	
Motivation	Economic Interest	

Knowledge associated				
Report	IoC	Infrastructure	Malicious samples	Vulnerability
4	121	17	101	3

Recent reports		
2019/8/21	Silence 2.0 Going Global	alienvault
2019/1/24	Silence group targeting Russian banks via malicious CHM	alienvault
2020/3/30	New financially motivated attacks in Western Europe traced to Russian threat actors	Group-IB

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

TABLE 11
Anunak

Organization	Anunak	
Alias	Carbanak Carbon Spider GOLD NIAGARA FIN7	
Industry	External trade finance	
Disclosure	2016/12/9	
Recently active	2021/9/20	
Motivation	Cyber crime	

Knowledge associated				
Report	IoC	Infrastructure	Malicious samples	Vulnerability
72	4644	2168	2471	5

Recent reports		
2021/9/4	How Do You Run A Cybercrime Gang?	bushidotoken
2021/9/3	FIN7 Hackers Using Windows 11 Themed Documents to Drop Javascript Backdoor	thehackernews
2021/7/23	eSentire — Notorious Cybercrime Gang, FIN7, Lands Malware in Law Firm	alienvault
2021/7/16	Ongoing: APT organization FIN7 harpoon attacks using Windows 11 topic bait	nsfocusBlog
2021/1/4	FIN7 Organizes JSSLoader evolution	morphisec

intelligence standards. Regardless of the constructed system architecture and application of attribution, some potential problems exist in terms of practicability and scalability. This section discusses the limitations of CSKG4APT and the scope for future work.

The first limitation is timeliness. Currently, CSKG4APT cannot realize knowledge completion and automatic construction online for knowledge with heterogeneity and large-scale unstructured content. Thus, a time window T is required for collecting APT reports. CSKG4APT is updated after entity extraction; if the timeliness performance is enhanced as much as possible, the collected reports might be too few, resulting in wasted computing resources. If the time window T is too large, the reports would be sufficient, but the influence of CSKG4APT on providing decision assistance for security analysts would be small. Automatic construction and dynamics is also a challenge in the knowledge graph field[59].

The second limitation is relevance. CSKG4APT considers many standard systems in the CTI, and CAPEC is among the entity types of Attack_Pattern. However, a semantic gap exists between the low-semantic IoC and the high-level view of security operations. We can design a framework for correlating known attack data with ATT&CK. The security analyst can have a clearer understanding of the attack event by using the graph technology to restore the attack scenario corresponding to the ATT&CK. Moreover, by also considering the attack gang information accumulated by the knowledge graph, we can investigate methods of using the existing knowledge in security incidents to complete, infer, and predict to address the problems of insufficiency and discontinuity in complex attack contexts in CTI reports.

Finally, further analyses are required. As an important tool used by attackers, malware is also an important reference for security researchers in threat hunting. We can learn the behavior preferences of attackers more accurately by learning the behavior of malicious attacks. Question answering and recommender systems are also important research directions.

6 Conclusion

This paper presents CSKG4APT, a cybersecurity threat platform based on a knowledge graph. CSKG4APT constructs the fragmented information into an APT scene containing 12 node types and seven logical relationships by collecting and analyzing OSCTI. The platform generates an APT cybersecurity knowledge graph that complies with STIX, CYBOX, and other threat intelligence standards. In the experimental evaluation, our algorithm accurately extracted entities in English and Chinese CTI reports; we analyzed the attack organization information in CSKG4APT and displayed its portrait. The effect of CSKG4APT on attribution in a real campaign example was demonstrated to assist security analysts in making decisions. In the future, we plan to expand the application module to obtain more accurate campaign and attribution information.

References

[1] Advanced Persistent Threat, 2020. [Online]. Available: https://en.wikipedia.org/wiki/Advanced_persistent_threatInformation and communication technology

[2] APT Annual Review, 2021. [Online]. Available: https://securelist.com/apt-annual-review-2021/105127

[3] T. Zhihong, "Detection and traceability of high covert unknown threats in cyberspace," *Inf. Commun. Technol.*, vol. 14, no. 06, pp. 4–7, 2020.

[4] L. Yue *et al.*, "Overview of network security threat intelligence sharing and exchange," *Comput. Res. Develop.*, vol. 57, no. 10, pp. 2052–2065, 2020.

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

[5] Z. Zhu and T. Dumitras, "ChainSmith: Automatically learning the semantics of malicious campaigns by mining threat intelligence reports," in *Proc. IEEE Eur. Symp. Secur. Privacy*, 2018, pp. 458–472.

[6] Y. Ghazi, Z. Anwar, R. Mumtaz, S. Saleem, and A. Tahir, "A supervised machine learning based approach for automatically extracting high-level threat intelligence from unstructured sources," in *Proc. Int. Conf. Front. Inf. Technol.*, 2018, pp. 129–134.

[7] Y. Zhao, B. Lang, and M. Liu, "'Ontology-based unified model for heterogeneous threat intelligence integration and sharing," in *Proc. 11th IEEE Int. Conf. Anti-Counterfeiting Secur. Identification*, 2017, pp. 11–15.

[8] Y. Guo *et al.*, "CyberRel: Joint entity and relation extraction for cybersecurity concepts," in *Proc. Int. Conf. Inf. Commun. Secur.*, 2021, pp. 447–463.

[9] G. Husari, E. Al-Shaer, M. Ahmed, B. Chu, and X. Niu, "TTPDrill: Automatic and accurate extraction of threat actions from unstructured text ofCTI Sources," in *Proc. 33rd Annu. Comput. Secur. Appl. Conf.*, 2017, pp. 103–115.

[10] Z. Li, J. Zeng, Y. Chen, and Z. Liang, "AttacKG: Constructing technique knowledge graph from cyber threat intelligence reports," 2021, *arXiv: 2111.07093*.

[11] A. Singhal, "Introducing the knowledge graph: Things, not strings," Official Blog (of Google), 2012. Online]. Available: http://googleblog.blogspot.co.uk/2012/05/introducing-knowledge-graph-things-not.html

[12] W. Haofen, Q. Guilin, and C. Huajun, *Knowledge Graph: Method, Practice and Application*, Beijing, China: Publishing House Electron. Ind., 2019.

[13] STIX, 2022. [Online]. Available: https://oasis-open.github.io/cti-documentation/stix/intro

[14] CAPEC, 2019. [Online]. Available: http://capec.mitre.org/about/index.html

[15] C. N. Li and S. A. Thompson, "Mandarin chinese: A functional reference grammar," *J. Asian Stud.*, vol. 42, no. 3, pp. 10–12,1989.

[16] A. Alsaheel *et al.*, "ATLAS: A sequence-based learning approach for attack investigation," in *Proc. 30th USENIX Secur. Symp.*, 2021, pp. 3005–3022.

[17] CYBOX, 2020. [Online]. Available: http://cyboxproject.github.io/sample

[18] S. Caltagirone, A. Pendergast, and C. Betz, "The diamond model of intrusion analysis," Center for Cyber Intelligence Analysis and Threat Research Hanover Md: Ft. Meade, MD, USA, 2013.

[19] TAXII, 2019. [Online]. Available: https://taxiiproject.github.io/

[20] MANDIANT, "Sophisticated indicators for the modern threat landscape: An introduction to OpenIOC," White Paper, Jun. 2017. [Online]. Available: http://openioc.org/resources/AnIntroductiontoOpenIOC.pdf

[21] M.O.S.T.I. Platform, "Open standards for threat information sharing," 2020. [Online]. Available: http://www.misp-project.org/index.html

[22] V. Mulwad, W. Li, A. Joshi, T. Finin, and K. Viswanathan, "Extracting information about security vulnerabilities from web text," in *Proc. IEEE/WIC/ACM Int. Conf. Web Intell. Agent Technol.*, 2011, pp. 257–260, doi: 10.1109/WI-IAT.2011.26.

[23] A. Joshi, R. Lal, T. Finin, and A. Joshi, "Extracting cybersecurity related linked data from text," in *Proc. IEEE 7th Int. Conf. Semantic Comput.*, 2013, pp. 252–259, doi: 10.1109/ICSC.2013.50.

[24] R. Manikandan, K. Madgula, S. Saha, "TeamDL at SemEval-2018 task 8: Cybersecurity text analysis using convolutional neural network and conditional random fields," in *Proc. 12th Int. Workshop Semantic Eval.*, 2018, pp. 868–873.

[25] N. Dionísio *et al.*, "Cyberthreat detection from twitter using deep neural networks," in *Proc. Int. Joint Conf. Neural Netw.*, 2019, pp. 1–8.

[26] H. Gasmi, J. Laval, and A. Bouras, "Information extraction of cybersecurity concepts: An LST<approach," *Appl. Sci.*, vol. 9, no. 19, 2019, Art. no. 3945.

[27] T. Satyapanich, F. Ferraro, T. Finin, "CASIE: Extracting cybersecurity event information from text," in *Proc. AAAI Conf. Artif. Intell.*, 2020, pp. 8749–8757.

[28] T. Li, Y. Guo, and A. Ju, "A self-attention-based approach for named entity recognition in cybersecurity," in *Proc. 15th Int. Conf. Comput. Intell. Secur.*, 2019, pp. 147–150.

[29] Y. Gao, X. Li, H. Peng, B. Fang, and P. Yu, "HinCTI: A cyber threat intelligence modeling and identification system based on heterogeneous information network," *IEEE Trans. Knowl. Data Eng.*, vol. 34, no. 2, pp. 708–722, Feb. 2022, doi: 10.1109/TKDE.2020.2987019

[30] X. Liao *et al.*, "Acing the IoC game: Toward automatic discovery and analysis of open-source cyber threat intelligence," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur.*, 2016, pp. 755–766.

[31] G. Husari *et al.*, "TTPDrill: Automatic and accurate extraction of threat actions from unstructured text of CTI sources," in *Proc. 33rd Annu. Comput. Secur. Appl. Conf.*, 2017, pp. 103–115.

[32] J. Zhao *et al.*, "TIMiner: Automatically extracting and analyzing categorized cyber threat intelligence from social data," *Comput. Secur.*, vol. 95, 2020, Art. no. 101867.

[33] K. Satvat, R. Gjomemo, and V. N. Venkatakrishnan, "Extractor: Extracting attack behavior from threat reports," in *Proc. IEEE Eur. Symp. Secur. Privacy*, 2021, pp. 598–615.

[34] Y. Zhao, B. Lang, and M. Liu, "Ontology-based unified model for heterogeneous threat intelligence integration and sharing", in *Proc. 11th IEEE Int. Conf. Anticounterfeiting Secur. Identification*, 2017, pp. 11–15.

[35] E. Kiesling *et al.*, "The SEPSES knowledge graph: An integrated resource for cybersecurity," in *Proc. Int. Semantic Web Conf.*, 2019, pp. 198–214.

[36] Y. Deng *et al.*, "Knowledge graph based learning guidance for cybersecurity hands-on Labs," in *Proc. ACM Conf. Glob. Comput. Educ.*, 2019, pp. 194–200.

[37] M. Du *et al.*, "PRTIRG: A knowledge graph for people-readable threat intelligence recommendation," *Knowl. Sci. Eng. Manage.*, pp. 47–59, 2019.

[38] B. Mozzaquatro *et al.*, "An ontology-based cybersecurity framework for the Internet of Things," *Sensors*, vol. 18, 2018, Art. no. 3053.

[39] X-Force Exchange, 2022. [Online]. Available: https://exchange.xforce.ibmcloud.com

[40] 360, 2022. [Online]. Available: https://ti.360.net

[41] RedQueen, 2022. [Online]. Available: https://redqueen.tj-un.com/IntelHome.html

[42] Weibu, 2022. [Online]. Available: https://x.threatbook.cn

[43] U. Noor *et al.*, "A machine learning-based FinTech cyber threat attribution framework using high-level indicators of compromise," *Future Gener. Comput. Syst.*, vol. 96, pp. 227–242, 2019.

[44] Q. Li, Z. Yang, B. Liu, Z. Jiang, and J. Yan, "Framework of cyber attack attribution based on threat intelligence," *Proc. Int. Conf. Interoper Ability IoT 2016*, vol. 190. pp. 92–103, 2016.

[45] A. Warikoo, "The triangle model for cyber threat attribution," *J. Cyber Secur. Technol.*, pp. 1–18, 2021.

[46] P. Shakarian *et al.*, "Cyber attribution: An argumentation-based approach," Springer, Cham: Cyber Warfare., vol. 56, 2015, pp. 151–171

[47] H. Hettema, "Rationality constraints in cyber defense: Incident handling, attribution and cyber threat intelligence," *Comput. Secur.*, vol. 109, 2021, Art. no. 102396.

[48] D. Sahoo, "Cyber threat attribution with multi-view heuristic analysis," in *Handbook Big Data Analytics Forensics*, Cham, Switzerland: Springer, 2022, pp. 53–73.

[49] M. Belaoued, S. Mazouzi, "A Chi-square-based decision for real-time malware detection using PE-file features," *J. Inf. Process. Syst.*, vol. 12, no. 4, pp. 644–660, 2016.

[50] Scrapy-Redis, 2022. [Online]. Available: https://scrapy-redis.readthedocs.io/en/stable/

[51] Y. Zhou *et al.*, "CTI View: APT threat intelligence analysis system," *Secur. Commun. Netw.*, vol. 2022, 2022.

[52] J. Devlin *et al.*, "BERT: Pre-training of deep bidirectional transformers for language understanding," 2018, *arXiv: 1810.04805*.

[53] MAEC, 2020. [Online]. Available: http://maecproject.github.io

[54] CVE, 2021. [Online]. Available: http://cve.mitre.org/

[55] APT28: AT the Center of the Storm[EB/OL], [Online]. Available: https://www2.fireeye.com/rs/848-DID-242/images/APT28-Center-of-Storm-2017.pdf

[56] H. Booth, D. Rike, and G. A. Witte, "The national vulnerability database (NVD): Overview," Nat. Inst. Std. Technol., Gaithersburg, USA, Tech. Rep., 2013.

[57] S. Caltagirone, A. Pendergast, and C. Betz, "The diamond model of intrusion analysism," *Center Cyber Intell. Anal. Threat Res. Hanover Md*, 2013.

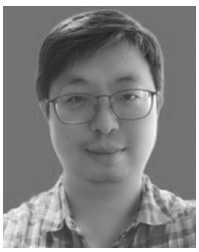
[58] J. Yang, Y. Zhang, L. Li, and X. Li, "YEDDA: A lightweight collaborative text span annotation tool," in *Proc. Annu. Meeting Assoc. Comput. Linguistics*, 2018, pp. 31–36.

[59] S. Ji, S. Pan, E. Cambria, P. Marttinen, and P. S. Yu, "A survey on knowledge graphs: Representation, acquisition, and applications," *IEEE Trans. Neural Netw. Learn. Syst.*, vol. 33, no. 2, pp. 494–514, Feb. 2022.

[60] JSSLoader:Recoded and Reloaded, [Online]. Available: https://www.proofpoint.com/us/blog/threat-insight/jssloader-recoded-and-reloaded

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.

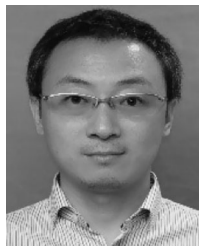
Yitong Ren is currently working toward the PhD degree with the Cyberspace Institute of Advanced Technology (CIAT), Minis-try of Education, Guangzhou University, Guangzhou, China. She has published some papers in journals and conference proceedings. Her current research interests include APT, knowledge graph, graph neural network and causal inference.



Yanjun Xiao is currently working on PINGXING Lab, Nsfocus Technology Group Company.

Yinghai Zhou is currently working toward the MS degree with Guangzhou University. His current research interests include cyberspace threat intelligence and intelligent detection and traceability of APT threat in cyberspace.

Zhiyong Zhang is currently working toward the master's degree with the Cyberspace Institute of Advanced Technology (CIAT), Ministry of Education, Guangzhou University, Guangzhou, China. He current research interests include APT, malware, NLP, and graph neural network.



Zhihong Tian (Senior Member, IEEE) received the BS, MS, and PhD degrees in computer science and technology from the Harbin Institute of Technology, Harbin, China, in 2001, 2003, and 2006, respectively. He is currently a professor, and dean with the Cyberspace Institute of Advanced Technology, Guangzhou University, Guangdong Province, China. He is honored as Pearl River Scholar in Guangdong Province. He is also a part-time professor with Carlton University, Ottawa, Canada. Previously, he served in several academic and administrative positions with the Harbin Institute of Technology. He has authored more than 200 journal and conference papers. His research interests include computer networks and cyberspace security. His research has been supported in part by the National Natural Science Foundation of China, National Key research and Development Plan of China, National High-tech R&D Program of China (863 Program). He also served as a member, chair, and general chair of a number of international conferences. He is a distinguished member of the China Computer Federation.

▷ **For more information on this or any other computing topic, please visit our Digital Library at** www.computer.org/csdl.

Authorized licensed use limited to: Institute of Information EngineeringCAS. Downloaded on February 14,2025 at 03:01:06 UTC from IEEE Xplore. Restrictions apply.